SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Deemed as University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I M. Ajay 192312542 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

M. Ajay
192312542

① Unauthorized Slope Expansion During Penetration Testing

When a company provides only a one-line email authorization without a clearly defined scope exploiting a vulnerability discovered in an untested system would be unethical and potentially illegal. Even if the vulnerability is critical the tester must not assume that the authorization covers every connected system.

Ethical approach:

* Stop further testing: Avoid exploiting the vulnerabilities or accessing sensitive information until permission is clarified.
* Document the finding: Record the affected system vulnerability details potential impact and evidence obtained without causing harm.
* Inform the client: Report the critical vulnerability to the authorized contact and explain its possible consequence.
* obtain written authorization: Request explicit permission to test the affected system including the scope permitted technique and limitations
* Follow responsible disclosure: Share the findings securely with the appropriate stakeholders and become suitable remediation.

Justification: Ethical hacking requires explicit authorization confidentiality, accountability, minimizing term. A critical vulnerability does not justify exceeding

the agreed, SCOPE. written, permission, protects, both the organization, and the penetration, tester.

② SQL injection, in a Production, Database, containing Financial Data:

When a Penetration, test, reveals, an SQL injection, vulnerability, in a, production, database, containing customer, financial, information, the test, must, prioritize data, service, availability, over, demonstrating, the full impact

Plan to Proceed Safely:

1. STOP risking EXPLOITation: DO NOT, Execute, queries that modify, delete, or EXPOSE real, customer, records
2. use minimal, validation: confirm, the vulnerability through, safe, non-destructive, testing techniques, perfectly in a staging environment, with, synthetic, data.
3. Notify the client immediately: Inform, the authorized security, contact, about, the vulnerability, and its potential, impact

Precaution required before, testing begins:

* obtain, signed authorization, and define, the EXACT testing SCOPE
* Identify Production, systems, sensitive, databases, for Prohibited, testing methods
* Establish, emergency, contacts, and Procedure, for stopping, the test
* Agree, on backup, recovery, data-handling, incident environment - reporting Procedure

Accidental Denial of Service During a Penetration Test

A denial of service (DOS) condition occurs when a system becomes unavailable to legitimate users because of excessive or harmful requests

Prevention of Denial of Service

To prevent this incident I should have reviewed the testing scope and identified activities that could affect server availability.

Immediate Action After the incident:

I would immediately stop the penetration test and inform the clients designated contact. I would operate with the IT-team to help serve the prevent further disruption

Incident Reporting and Documentation:

I would record the time of the incident the testing activities performed and the observed affects I would preserve relevant logs and provide an honest explanation of what happened

Conclusion:

Ethical hackers must take responsibility for incidents caused during testing. Stopping the test informing the client supporting recovery and documenting the incident are essential steps.

(4) Testing without informing the IT department

A client may request a covert penetration test to evaluate whether its IT department can detect and respond to real-world attacks. However conducting such a test without informing the IT team creates ethical legal and operational risks

Ethical and practical risks:
*service disruption: testing activities may unin
affect business-critical systems
Ethical and service disruption: security monitoring tools
may trigger alerts leading to unnecessary incidents
escalation.
Legal complications: Testing without sufficient
authorization may violate laws contracts or third
party service.
How to structure the Engagement safety
* obtain written authorization from an authorized
executive or system owner.
* Agree a clear stop condition including service
outages
Justifications: A covert test can measure real
world detection capabilities but secrecy must not
eliminate accountability over safety controls proper
planning protects the organization while allowing the team
to assess it incident response readiness

(5) Red-Team Exercise vs Vulnerability Assessment in a
A red team exercise and a vulnerability assessment
a both cybersecurity activities but they have different
objectives methods and levels of operational risks.

(a) Vulnerability Assessment:
A vulnerability assessment systematically
identifies and evaluates security weaknesses in systems
apps networks etc.

Approach:

* Identifies assets within the approved scope
* Scan for outdated software and known vulnerabilities
* Validate findings using safe controlled techniques
* Classify vulnerabilities according to severity & business impact.

Ethical considerations:

* Avoid assets within the approved scope.
* Scan for outdated software and known vulnerabilities
* Validate findings using safe techniques
* Protect vulnerability reports and sensitive technical information.

Ex: Identifying an outdated website server or an incorrectly configured access control that could expose banking information.

Red-Team Exercise:

Objective - Test the banks overall security and incident response capabilities

Approach - simulate authorized attacks such as phishing etc.

Ethics - obtain written authorization, define rules of engagement, protect customer data and establish emergency SOP, produces.